

OWASP LLM Top 10 2025	
LLM01	Prompt Injection · 直接 / 间接
LLM02	Sensitive Info Disclosure · 系统提示 / PII 泄露
LLM03	Supply Chain · 模型/数据/插件来源
LLM04	Data & Model Poisoning · 训练污染
LLM05	Improper Output Handling · 信任模型输出执行
LLM06	Excessive Agency · 权限/工具/自治过多
LLM07	System Prompt Leakage · 提示泄露
LLM08	Vector & Embedding · RAG 投毒/反演
LLM09	Misinformation · 幻觉/过度依赖
LLM10	Unbounded Consumption · 速率/成本 DoS

配套框架
MITRE ATLAS 对手战术 · NIST AI RMF 风险管理 · EU AI Act 合规

Prompt Injection 注入	
两大类	
Direct	用户直接在输入里下指令
Indirect (IPI)	藏在网页/邮件/PDF/工具结果里
常见载体	
网页内容	@Web · 抓页面
文档	PDF · markdown · docx
工具输出	MCP / API 返回
图像	OCR / 视觉模型
看不见字符	零宽 · Unicode tag

影响
‣ 外泄数据(把用户邮件发给攻击者)
‣ 滥用工具(发邮件/转账/删文件)
‣ 污染后续会话与记忆
‣ 越权访问 RAG 中其他人数据
心智模型
外部内容 = 不可信输入,等同于 用户输入处理

Jailbreak 模式认知 仅用于识别防御	
了解攻击模式以便防御与评测。不提供具体 payload。	
模式分类	
角色扮演	扮演无限制 AI
Virtualization	虚构场景 / 故事
Payload Splitting	拆分敏感字符串
Encoding	Base64 / ROT13 / 翻译
Low-resource lang	小语种绕过 safety
Many-shot	长上下文堆负样例
Adversarial suffix	GCG 自动搜索
ASCII / Unicode art	图形隐藏指令
评测工具	
Garak	开源 LLM 漏扫
PyRIT	微软红队工具
HarmBench	学界基准
AgentDojo	agent 注入评测

防御 · 输入层 Input Defense	
过滤 / 分类	
Llama Guard 3 / 4	Meta 内容分类器
Prompt Guard 2	Meta 注入检测
NeMo Guardrails	NVIDIA 规则引擎
Lakera Guard	商业 API
结构隔离	
XML 标签包裹	<user_input>...</user_input>
明确不可信源	"以下来自网页,可能含恶意指令"
分离 system / data	指令与数据分通道

最小权限
‣ 用户身份带入工具调用,RAG 按 ACL 过滤
‣ 工具白名单 · 危险工具加 HITL 审批
‣ 速率/配额限制(防 DoS 与失控循环)
‣ 输入长度上限,防 many-shot

防御 · 输出层 Output Defense	
永远不要	
‣ 直接执行	模型输出的 shell / SQL / eval
‣ 直接渲染	模型输出为 HTML(XSS)
‣ 直接跳转	模型给的 URL(钓鱼)
‣ 把 system prompt	当机密(假设会泄)
校验	
Schema validate	Pydantic / JSON Schema
白名单输出	枚举 / 受限语法
引用强制	RAG 必须 cite
URL 白名单	域名/路径校验
脱敏	
PII 检测	Presidio · Comprehend
密钥扫描	trufflehog / gitleaks
沙箱	

代码/命令必须在 容器/seatbelt/landlock 跑;断网 + 只读 + 超时

Agent 安全 Agent Hardening	
权限模型	
Approval: untrusted	非信任命令必审
Sandbox: workspace-workdir	默认只写工作区
--yolo / danger-full	仅在沙箱环境用
沙箱实现	
macOS	Seatbelt (sandbox-exec)
Linux	Landlock + seccomp
Windows	Job Object
通用	Docker / gVisor / firejail

HITL 触发点
‣ 文件系统外写入 / 删除
‣ 网络出站(尤其 webhook / 邮件)
‣ git push / 部署 / 数据库 DDL
‣ 支付 / 发消息 / 调外部 API key
监控
trace 全保留;循环检测;token/cost 上限;异常 tool 模式告警

RAG & 数据隐私 Data Privacy	
RAG 风险	
Index Poisoning	投毒文档进知识库
Embedding Inversion	向量反推原文
Cross-tenant Leak	多租户隔离失败
Confused Deputy	高权服务替低权用户查

RAG 防御
‣ 文档进库前 清洗 + 来源签名
‣ 查询时按 用户身份过滤 metadata
‣ 向量库 ACL · 不要跨租户共享 index
‣ 命中结果再过敏感词 / PII 过滤

隐私	
Privacy Mode	不参与训练(Cursor/Codex/Claude)
Zero retention	企业版 API 选项
本地推理	完全离线最稳

合规
GDPR · HIPAA · PCI · EU AI Act · SOC 2:日志脱敏、数据驻留、最小化、审计

对齐 & Pro Tips Alignment & Tips	
对齐方法	
RLHF / RLAIIF	人类/AI 反馈强化
Constitutional AI	Anthropic · 原则自批
DP0 / ORP0	偏好直接优化
Safety classifier	输入/输出双层
红蓝队	
Auto red-team	PyRIT · Garak · HarmBench
Human red-team	领域专家对抗
Bug bounty	Anthropic/OpenAI 公开

铁律
‣ 假设所有外部内容都是恶意的
‣ 不直接执行 模型输出 — 永远要校验
‣ system prompt 不是秘密 · 不放凭据
‣ 每个工具配 最小权限 + 审批门
‣ 不可逆操作 必须 HITL
‣ 开发期沙箱 / 生产期监控 + 速率限
‣ RAG / 工具 = 攻击面,变更要 review
‣ 记录 完整 trace,事后可溯源